WEEK 5 — VAPT TOOLS

Vulnerability Assessment & Penetration Testing
Practical Learning Report

Internship	DG Interns Hub — Cyber Security Internship
Week	Week 5
Focus	Nmap • Nikto • Burp Suite
Platform	Linux Mint
Authorized target	testasp.vulnweb.com
Target IP observed	44.238.29.244
Assessment date	7 October 2026

Assessment note: The assignment initially specified testphp.vulnweb.com. That host resolved but did not accept HTTP/HTTPS connections from the user's network. An officially provided VulnWeb practice target, testasp.vulnweb.com, was therefore used for the practical work.

1. Executive Summary

This week introduced practical Vulnerability Assessment and Penetration Testing (VAPT) using three commonly used tools: Nmap for network/service enumeration, Nikto for web-server checks, and Burp Suite for HTTP request/response inspection. The assessment was performed from Linux Mint against the authorized VulnWeb practice application testasp.vulnweb.com.

The assessment identified an exposed HTTP service on TCP port 80 running Microsoft IIS 8.5, together with several web-security observations. The most notable observations were an ASP session cookie without the HttpOnly attribute, absence of the anti-clickjacking X-Frame-Options header, support for the HTTP TRACE method, server technology disclosure through headers, ETag information disclosure, and an exposed login page. These observations were treated as findings for further review rather than assuming that every observation represented an exploitable vulnerability.

Assessment outcome

Area	Result
Nmap discovery	80/tcp open; HTTP service detected
Service detection	Microsoft IIS httpd 8.5; ASP.NET/Windows fingerprinting
Nmap -A	Cookie flag and TRACE observations; traceroute completed; OS detection inconclusive
Nikto	9 reported items including missing security header, cookie flag, ETag disclosure and exposed
Burp Suite	Captured GET requests and HTTP 200 responses; inspected headers, cookies and parameters

Overall conclusion: The exercise successfully demonstrated the basic VAPT workflow: discover → enumerate → inspect → correlate findings → document risk and recommendations.

2. Scope, Authorization & Methodology

2.1 Scope

Testing was limited to the VulnWeb practice environment supplied for security training. No unrelated public websites or systems were tested. The working target for the assessment was:

Target hostname	testasp.vulnweb.com
Observed IP	44.238.29.244
Protocol tested	HTTP
Observed port	80/tcp
Client platform	Linux Mint
Tools	Nmap 7.94SVN, Nikto 2.1.5, Burp Suite

2.2 Methodology

1. Reconnaissance and port scanning: Nmap SYN scanning was used to identify reachable TCP services. 2. Service enumeration: Nmap service/version detection identified the HTTP implementation. 3. Comprehensive enumeration: Nmap -A collected additional HTTP, script, traceroute and fingerprinting information. 4. Web-server assessment: Nikto checked headers, methods, files and common web-server issues. 5. HTTP inspection: Burp Suite captured normal application requests and responses so that methods, paths, headers, cookies and parameters could be examined.

2.3 Limitations

The target is a public training application and therefore findings represent observations in the supplied lab environment, not a production security assessment. Nmap OS detection was not conclusive in the final scan. Burp evidence in this report shows passive inspection of captured traffic; no destructive exploitation or unauthorized modification was performed.

3. Nmap Assessment

3.1 SYN Scan

Command used: `sudo nmap -sS testasp.vulnweb.com`

The basic SYN scan confirmed that the host was reachable and that TCP port 80 was open. The scan reported 999 other TCP ports as filtered, meaning Nmap did not receive the expected response from those ports.

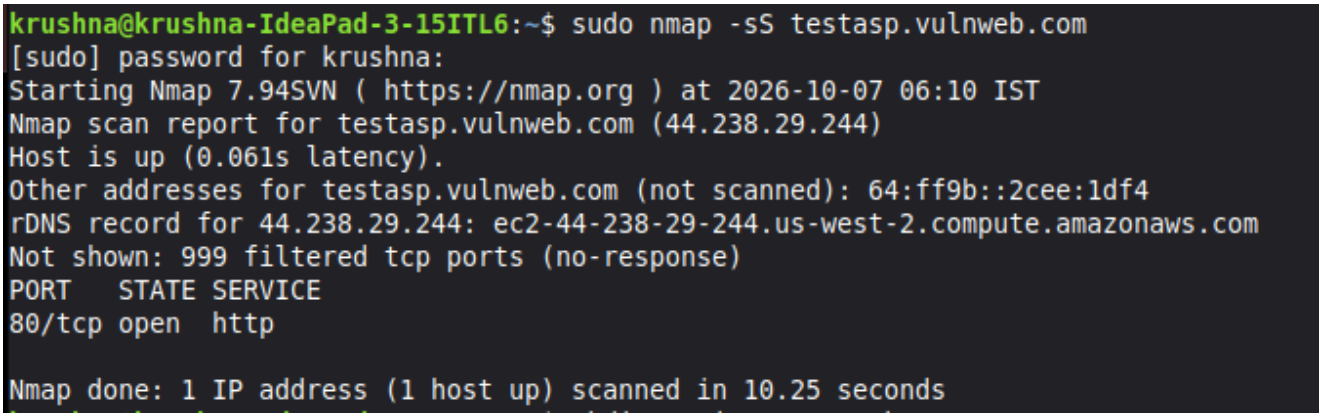


Figure 1 — Nmap SYN scan showing 80/tcp open and 999 filtered TCP ports.

Interpretation: Port 80 being open indicates an HTTP service is accepting TCP connections. It does not, by itself, prove that the service is vulnerable.

4. Nmap Service & Version Detection

4.1 Service Enumeration

Command used: `nmap -sV testasp.vulnweb.com`

Nmap identified the service on port 80 as Microsoft IIS httpd 8.5. The scan also associated the service with Windows and returned a Microsoft Windows CPE. This is useful for technology fingerprinting and for deciding which later checks are relevant.



Figure 2 — Nmap service/version detection identifying Microsoft IIS httpd 8.5.

Security relevance: Version information is valuable to an assessor because it narrows the technology stack, but service fingerprinting alone should not be presented as proof of a vulnerability.

5. Comprehensive Nmap Scan

5.1 Aggressive Scan

Command used: `nmap -A testasp.vulnweb.com`

The comprehensive scan confirmed IIS 8.5 and the application title acuforum forums. It also reported that the ASP session cookie did not have the HttpOnly flag and that TRACE was listed as a potentially risky HTTP method. The scan additionally performed traceroute. In the final run, OS fingerprinting was inconclusive and therefore no definitive operating-system claim is made in this report.

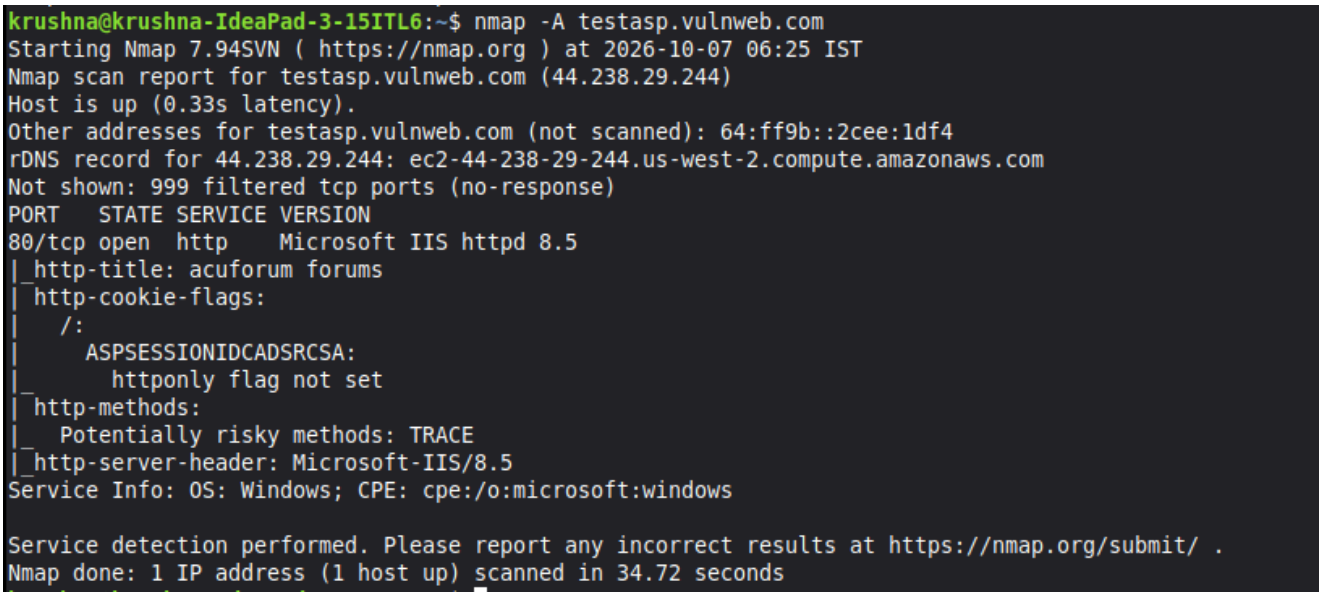


Figure 3 — Nmap -A output showing HTTP details, cookie flag, TRACE and inconclusive OS fingerprinting.

> Important distinction: 'HttpOnly flag not set' and 'TRACE enabled' are security observations that require context. They are not equivalent to demonstrating session theft or successful exploitation.

6. Nikto Web-Server Assessment

6.1 Scan

Command used: `nikto -h http://testasp.vulnweb.com`

Nikto 2.1.5 reported several web-server and application observations. The output corroborated the missing HttpOnly cookie flag and the presence of TRACE, and added other useful observations such as the absence of X-Frame-Options, ETag information leakage, technology disclosure, and an exposed login page.

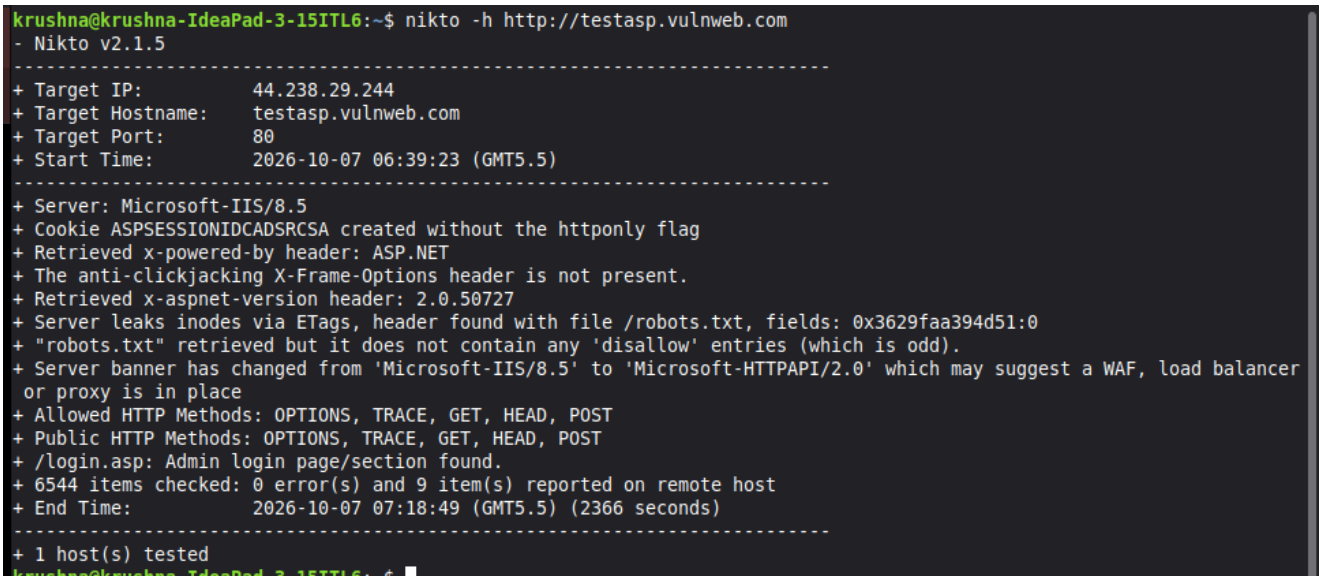


Figure 4 — Nikto 2.1.5 results for the authorized VulnWeb target.

The Nikto output states that 6,544 items were checked and 9 items were reported on the remote host. These results should be treated as automated indicators for manual validation rather than as a final vulnerability verdict.

7. Burp Suite HTTP Inspection

7.1 Captured Requests

Burp Suite was used to inspect normal HTTP traffic generated while browsing the authorized application. The captured requests demonstrate the HTTP method, requested path, Host header, user-agent, accepted content types, referrer, cookies and connection behavior.

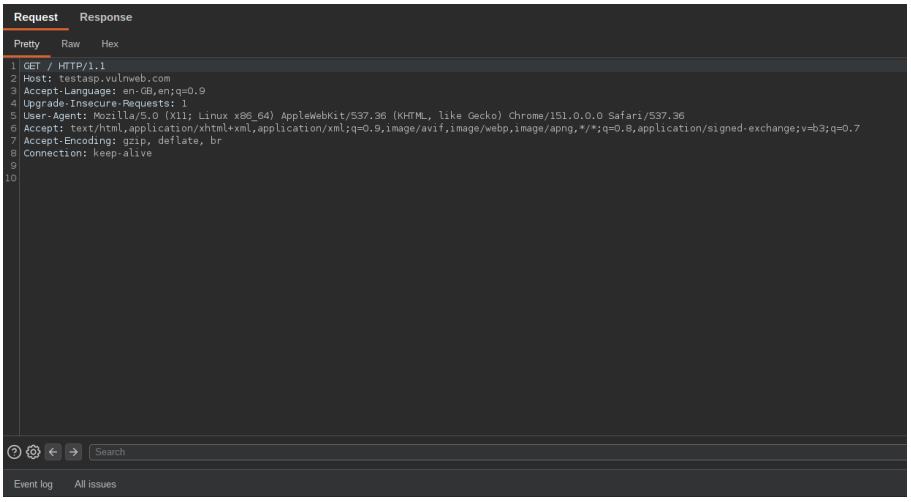


Figure 5 — Burp request: GET / HTTP/1.1.

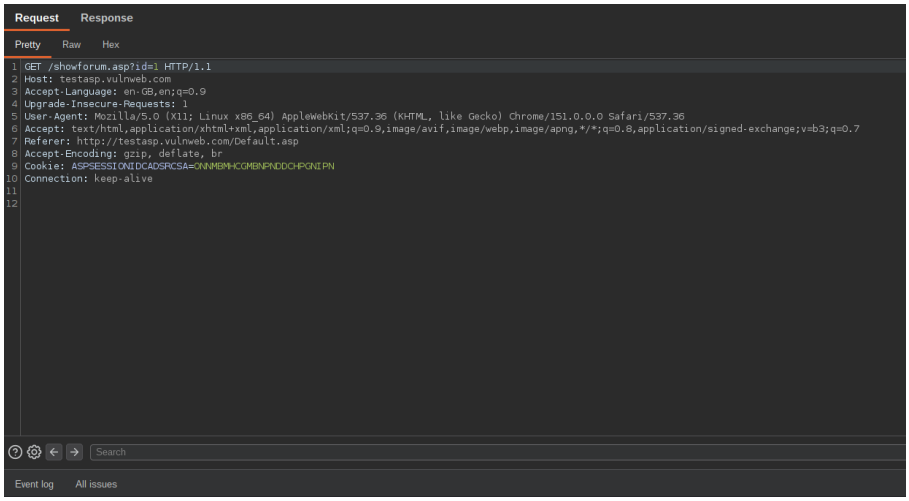


Figure 6 — Burp request: GET /showforum.asp?id=1 HTTP/1.1.

8. Burp Suite Response Analysis

The captured responses returned HTTP 200 OK and exposed useful server/application information in the response headers. The evidence shows Microsoft-IIS/8.5, ASP.NET, and an ASPSESSIONID cookie. The response bodies also exposed application titles such as 'acuforum forums' and 'acuforum Weather'.

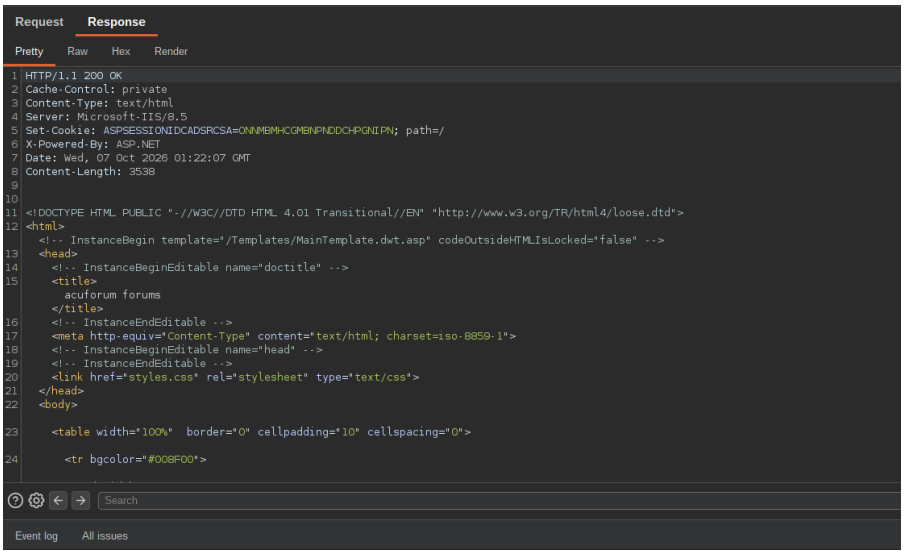


Figure 7 — Burp response showing IIS/ASP.NET headers and ASP session cookie.

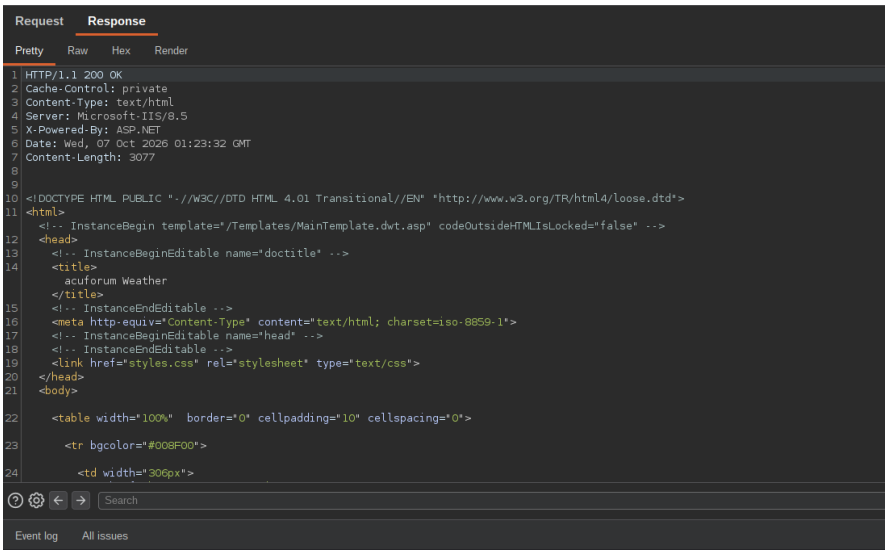


Figure 8 — Burp response showing the acuforum Weather application page.

Burp contribution to the assessment: It allowed the automated findings to be correlated with actual HTTP traffic. In particular, the session cookie observed in the response provides direct evidence that cookie security attributes are relevant to the application.

9. Findings & Risk Assessment

The following findings are based only on observations visible in the Nmap, Nikto and Burp evidence collected during the practical exercise.

ID	Finding	Evidence	Risk
F-01	ASP session cookie lacks HttpOnly	Nmap -A; Nikto; Burp response	Medium
F-02	X-Frame-Options header absent	Nikto	Low–Medium
F-03	TRACE HTTP method enabled	Nmap -A; Nikto	Low–Medium
F-04	Server/technology disclosure	Nmap -sV; Burp; Nikto	Low
F-05	ETag reveals inode information	Nikto	Low
F-06	Login page exposed at /login.asp	Nikto	Informational / review

F-01 — Cookie security attribute

The ASPSESSIONID cookie was observed without the HttpOnly attribute. Recommendation: configure session cookies with HttpOnly and Secure where appropriate, and review SameSite policy according to the application's authentication design. This reduces exposure of session cookies to client-side scripts but does not by itself prevent XSS.

F-02 — Missing anti-clickjacking header

Nikto reported that X-Frame-Options was not present. Recommendation: use an appropriate anti-framing policy, preferably through a suitable Content-Security-Policy frame-ancestors directive and/or X-Frame-Options where compatibility requires it.

F-03 — TRACE method

TRACE was listed as an allowed/potentially risky HTTP method. Recommendation: disable TRACE if it is not required by the application or infrastructure.

10. Recommendations & Conclusion

10.1 Recommended Hardening

• Set the HttpOnly attribute on server-side session cookies and review Secure/SameSite settings.

• Add an anti-clickjacking policy such as Content-Security-Policy frame-ancestors and/or X-Frame-Options.

• Disable the HTTP TRACE method unless a documented business or infrastructure requirement exists.

• Minimize server and framework version disclosure in response headers where practical.

• Review ETag configuration if inode information is unnecessarily exposed.

• Protect administrative/login endpoints with appropriate authentication, authorization, monitoring and rate limiting.

• Repeat testing after remediation to verify that security headers and methods have changed as intended.

10.2 Conclusion

The Week 5 practical exercise successfully demonstrated a basic VAPT workflow using Nmap, Nikto and Burp Suite. Nmap established the exposed attack surface and service technology, Nikto automated common web-server checks, and Burp Suite provided direct visibility into HTTP requests, responses, headers, cookies and application paths.

The most important lesson from the exercise is that automated tools produce evidence and leads, not automatic proof of compromise. Findings such as a missing HttpOnly flag, an enabled TRACE method or a missing security header must be interpreted in context and, where appropriate, manually validated before being described as exploitable vulnerabilities.

Assessment status: Practical VAPT tasks completed on the authorized VulnWeb training target. Evidence screenshots captured for Nmap, Nikto and Burp Suite.